

# **SAP GRC Rule Set Simulation**

## **1. Project Overview**

This project aims to simulate the process of how organizations assess access risk by employing a rule-based system, similar to the system used by SAP GRC Access Control.

In an enterprise SAP system, if there is improper access of the system by the users, it may lead to a situation where an individual has the capability to carry out contradictory activities within the financial or procurement process. If an individual has the capability to carry out multiple critical activities within the process, then it may lead to fraud.

To avoid these risks, organizations implement a technique called Segregation of Duties (SoD). This technique ensures that business activities are not performed by a single entity but are instead shared among multiple entities.

The purpose of this project is to demonstrate how risks associated with accessing a system can be identified using a structured rule set model.

The simulation includes:

- A risk catalog
- Business function definitions
- SAP transaction actions
- Technical authorization permissions
- Conflict rule definitions
- User role assignments
- Access risk analysis results

These elements of the simulation recreate the simplified workflow process of the SAP GRC access governance.

## **2. SAP GRC Rule Hierarchy**

In SAP GRC, access risks are analysed using a structured hierarchy. The hierarchy consists of four layers:

Risk → Function → Action → Permission

Each level represents a different abstraction of access control within the SAP system.

### **Risk:**

A risk is defined as a possible failure in business control, which can occur when a user performs conflicting business activities.

Risks are identified and defined at the highest level and refer to the business impact of improper access combinations.

Examples of risks considered in this project include:

- Vendor fraud
- Invoice fraud
- Procurement fraud
- Financial data manipulation

Each risk is assigned a severity level such as Critical or High depending on the potential financial or operational impact.

**Function:**

A function represents a business activity performed within the SAP system. Functions map technology access to meaningful business operations.

Some examples of functions used in the project are:

- Maintaining vendor master data
- Executing vendor payments
- Posting vendor invoices
- Approving vendor invoices
- Creating purchase orders
- Approving purchase orders

Each function is associated with a particular risk within the risk catalog. For example, maintaining vendor master data and processing vendor payments relate to vendor fraud risk.

The functions enable organizations to analyse access conflicts based on business process, not merely on transactions.

**Action:**

An action is a representation of the SAP transaction codes that are used to carry out business activities.

Transaction codes are the commands used to execute operations within the SAP system.

Examples of the action in the project:

- Transaction for creating vendor records
- Transaction for changing vendor information
- Transaction for executing vendor payments
- Transaction for posting vendor invoices
- Transaction for approving invoices
- Transactions used in procurement processes

Each action is related to a function to define which system transaction enables the business activity.

This mapping helps organizations to identify the system operations that produce business risks.

**Permission:**

Permissions are the technical authorization objects and field values that provide users with access to SAP transactions.

Authorization objects are the lowest level of authorization in SAP security. They define what a user can do in a transaction.

Permissions usually include:

- Authorization object name
- Activity type
- Field values controlling system behaviour

These permissions are then associated with roles, which are eventually associated with users.

By linking permissions to actions, organizations can trace access risks at the level of technical authorization.

### **3. Risk Catalog Implementation**

The first step in the project was to define a risk catalog.

The risk catalog lists the possible access risks that may occur when users carry out conflicting business activities.

There are some key financial and procurement risks that are monitored in the enterprise SAP system.

Examples of such defined risks include:

- Vendor fraud risk, which may arise if the user has the capability to update the vendor master data as well as make vendor payments.
- Invoice manipulation risk, which may arise if the user has the capability to post vendor invoices as well as approve the same invoices.
- Procurement fraud risk, which may arise if the user has the ability to create purchase orders as well as approve purchase orders.
- Financial manipulation risk, which may arise if the user has the ability to update the general ledger configuration as well as update the journal entries.

These risks are the usual risks associated with internal controls in the finance and procurement processes.

### **4. Function Catalog Implementation**

After defining risks, the next step was to identify the business functions related to those identified risks.

Functions refer to the operational activities that users carry out as part of their daily business operations.

For instance, the vendor fraud risk is related to functions such as maintaining vendor master data and processing vendor payments.

Similarly, the invoice manipulation risk is related to the posting of vendor invoices and the approval of vendor invoices.

By relating functions to risks, the project is creating a bridge between business operations and access risk analysis.

### **5. Action Catalog Implementation**

The next step was to identify the SAP transaction codes used to support the functions.

These codes represent the operations performed by the users at the system level.

Each transaction has a specific business function.

For example, the functions of vendor management are related to those who used to carry out transactions for creating or modifying vendor data, and payment processing functions are related to those who used to carry out transactions for executing vendor payment.

In the process of procurement, the creation and approval of purchase orders are assigned to their functions.

This is an example of how activities in a system are related to operations at a business level.

## **6. Permission Catalog Implementation**

The permission catalog lists the technical authorization objects used to manage access to SAP transactions.

The authorization objects determine the activities that users are permitted to carry out.

Each of the permissions within the project has the following:

- An authorization object
- A specific field for an activity
- A value to define the operation allowed

These permissions define the technical enforcement level of SAP security.

The project links permissions to specific actions, illustrating how low-level access rights feed into business functions or risks.

## **7. Rule Set Matrix**

After risks, functions, actions, and permissions had been defined, a rule set matrix was created.

The rule set matrix is a matrix that specifies which combinations of functions should not be assigned to a given user.

For example, a rule can be created that states that a user should not be able to both maintain vendor master data and perform vendor payments.

Similarly, another rule can be created that ensures a user should not be able to both post invoices and approve invoices.

These rules are the basis for which Segregation of Duties is analysed.

If user access assignments are analysed based on this matrix, conflicts can be automatically detected.

## **8. User Role Assignment**

The project then simulates real-world SAP access by assigning roles to users.

Roles are groups of permissions that allow users to carry out specific business activities.

Each user is given a role that enables them to carry out certain activities in the simulation.

There are some users who are intentionally assigned roles with conflicting functions. This was done to show how SoD conflicts are detected during access analysis.

By mapping these roles to their associated functions and then mapping these functions to risks, the project can simulate how a real organization would assess its access control risks.

## **9. Access Risk Analysis**

The final step in the project is to evaluate the user role assignments against a set of rules that have been defined.

If a user is assigned a role that allows them to perform two conflicting functions, it is considered a Segregation of Duties violation.

The process produces a report that includes:

- The user with the conflicting access
- The associated risk

- The level of severity of the conflict
- The remediation action recommended

The process is a simulation of the Access Risk Analysis feature available with SAP GRC Access Control.

## **10. Conflict Remediation and Mitigation**

Once the conflict is identified, the risk must be removed or mitigated.

The most frequently applied method to resolve the problem is to remove one of the conflicting roles from the user.

The second method is to design the roles so that the conflicting permissions are separated into different job functions.

In some situations, conflicts cannot be removed due to operational requirements. In these cases, organizations implement mitigation controls.

Examples of mitigation controls include:

- Manager approval requirements
- Monitoring by internal audit teams
- Logging and reviewing sensitive transactions
- Periodic access reviews

These controls reduce the risk associated with unavoidable access conflicts.

## **11. Conclusion**

This project aims to provide a basic example of how the rule-based access governance model can be implemented in the SAP system.

Access analysis based on the following hierarchy can help identify access risks effectively for the organization:

Risk -> Function -> Action -> Permission

The project demonstrates how business risks can be linked to system functions, transactions, and permissions, enabling an organization to identify violations of Segregation of Duties and take appropriate remediation steps.

This process is structured and provides the basis for access governance solutions such as SAP GRC Access Control.